

Section 05



Industrial Security (Master)

Section 05 – Secure-by-Design Architectures

Secure-by-Design Architectures

Lecture Notes

Department of Computer Science

- 1 Why Design First
- 2 Pattern Library
- 3 Procurement & Contracts
- 4 Trade-offs
- 5 Migration from Brownfield

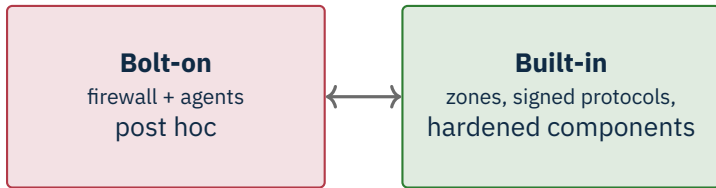
By the end of this section you will be able to

- Translate security requirements into early-design decisions on a greenfield plant.
- Apply IEC 62443 zones, conduits and target SLs from the FEED phase.
- Choose vendor-agnostic patterns: data diodes, brokered access, immutable backups.
- Make security trade-offs explicit and defensible to operators and finance.
- Build the contractual artefacts (vendor SDL, SBOM, ATPs) that survive procurement.

1

Why Design First

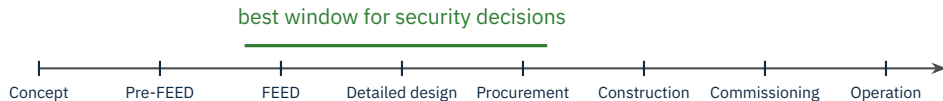
Section 05 – Secure-by-Design Architectures



Cost curve

Security retrofits in OT typically cost 5–10× a design-phase decision and take a planned outage. Built-in choices avoid both.

Source: INL CCE programme, multiple case studies 2018–2022.



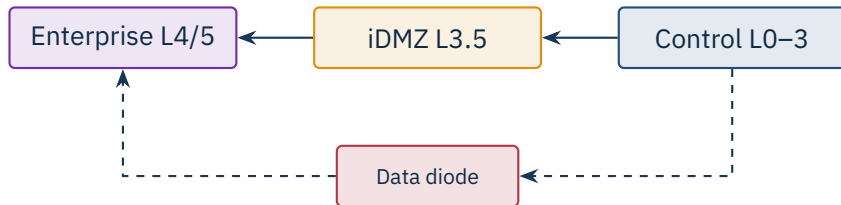
FEED phase

Front-End Engineering Design is when zones, conduits, SLs become contractually binding. Earlier = cheaper; later = compromised.

2

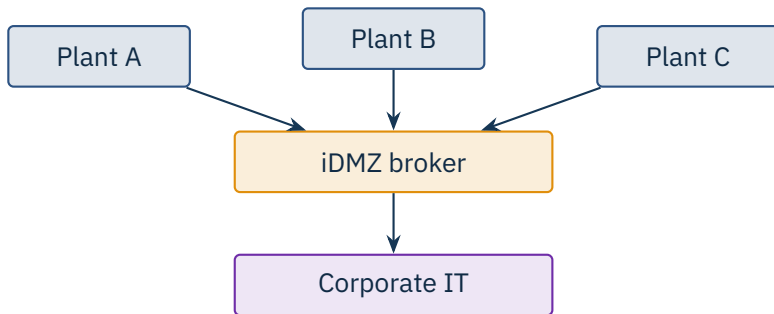
Pattern Library

Section 05 – Secure-by-Design Architectures



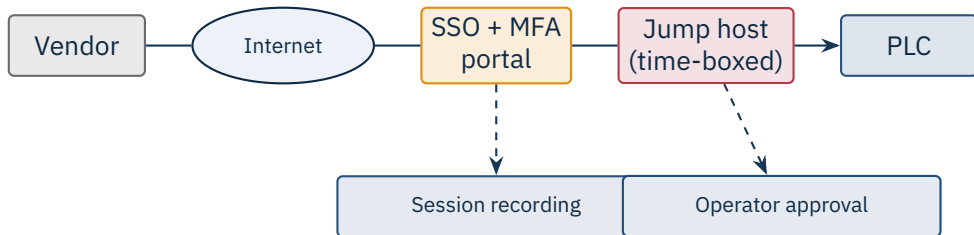
When it earns its cost

SIS-adjacent zones; export of safety telemetry to the corporate side; regulatory reporting feeds.

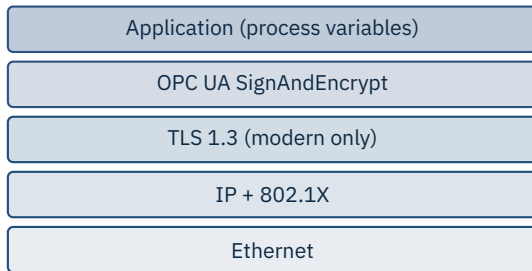


Multi-site benefit

Single point of policy enforcement for vendor remote access, historian replication, software updates – across all plants.



Source: Cyolo / Claroty xDome Secure Access / Dispel design patterns, 2020–2024.



Future-proofing

Specify in procurement: TLS 1.3+, modern cipher suites, support for cert rotation, and an explicit upgrade-path commitment from the vendor.



Test restore quarterly

Backups that have never been restored are not backups.

3

Procurement & Contracts

Section 05 – Secure-by-Design Architectures

- Conformance to IEC 62443-4-1 (Secure Development Lifecycle).
- SBOM in CycloneDX or SPDX delivered with every release.
- Threat modelling for the product, reviewed every major release.
- Vulnerability handling per ISO/IEC 30111 with SLA on disclosure.
- Long-term support commitment (e.g. 10 years from delivery).

Contractual leverage

Bake these into the purchase order. Vendors that cannot deliver an SBOM today should not be on a 20-year capital-investment list.

Source: IEC 62443-4-1:2018 | ISO/IEC 30111:2019 | OWASP CycloneDX, SPDX.

1. Hardening check (no default passwords, no test accounts)

2. Firmware integrity (vendor signature verified)

3. Network traffic baseline (passive PCAP for 24h, signed by vendor)

4. Vuln scan (vendor-approved tool, results delivered with system)

5. Backup/restore drill before go-live

4

Trade-offs

Section 05 – Secure-by-Design Architectures

Decision	Security win	Operational cost
SignAndEncrypt OPC UA Strict iDMZ MFA on jump host Application allow-list Data diode	integrity, confidentiality blast-radius limit credential theft mitigated malware execution blocked one-way egress only	cert lifecycle, vendor support multi-hop for engineers operator interruption change control overhead no remote control at all

- Frame as: “If we do X, residual risk is Y, cost is Z.”
- Pair every accepted residual with a review date.
- Capture in a register countersigned by safety + operations + executive.
- Re-open whenever the threat picture changes (new APT advisory, new sector incident).

Caution

“We accept the risk” without paper is no acceptance at all. Auditors and post-incident lawyers both want the paper.

5

Migration from Brownfield

Section 05 – Secure-by-Design Architectures

25-year-old PLC, vendor out of business

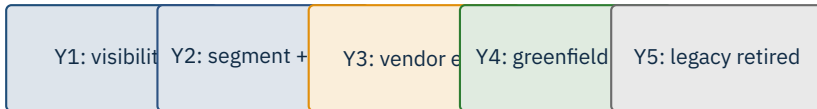
Engineering WS on Windows XP / 7

Serial-only DCS network; flat L2

Possible: wrapper appliances, network-layer compensations

Realistic horizon

Most secure-by-design wins arrive in the next capital project. Brownfield gets compensating controls and a roadmap.



Sequence matters

You cannot segment what you have not inventoried. You cannot retire what you have not replaced.

★ Key Takeaway: Build it in, not on

- Security decisions are cheapest in the FEED phase, most expensive after commissioning.
- A small library of patterns (Purdue+diode, iDMZ broker, brokered access, crypto-agile stack, immutable backup) covers most greenfield plants.
- Contractual artefacts (SDL, SBOM, ATPs) are the only thing that survives the procurement firewall.
- Trade-offs are unavoidable – write them down, name an owner, set a review date.
- Brownfield gets compensating controls and a sequenced migration roadmap.

- IEC 62443-2-1:2010 + Amd. 2019. *IACS asset owner programme*.
- IEC 62443-3-2:2020. *Security risk assessment for system design*.
- IEC 62443-3-3:2013. *System security requirements and security levels*.
- IEC 62443-4-1:2018. *Secure product development lifecycle (SDL)*.
- IEC 62443-4-2:2019. *Technical security requirements for IACS components*.
- INL. *Consequence-Driven Cyber-Informed Engineering (CCE)*, Bochman & Freeman, 2021.
- NIST SP 800-160 Vol. 1 Rev. 1. *Engineering Trustworthy Secure Systems*, 2022.
- ENISA. *Good practices for IACS*, 2020 onwards.
- OWASP. *CycloneDX Specification* for SBOMs.
- SPDX. *Software Package Data Exchange*.
- Owl Cyber Defense, *Waterfall Security: data-diode product literature for typical patterns*.
- Cyolo / Dispel / Claroty xDome Secure Access: *brokered remote-access design notes*.

End of Section 05



Secure-by-Design Architectures

Questions and discussion